

Contents

Cyber Security and Privacy — Volume 02	1
Lectures 11–20: Contingency, Policy, Risk Management, Industry Perspective	1
Lecture 11: Contingency Planning — Part 2	1
Lecture 12: Contingency Planning — Part 3	2
Lecture 13: Cybersecurity Policy — Part 1	4
Lecture 14: Cybersecurity Policy — Part 2	5
Lecture 15: Cybersecurity Policy — Part 3	6
Lecture 16: Risk Management — Part 1	7
Lecture 17: Risk Management — Part 2	9
Lecture 18: Risk Management — Part 3	10
Lecture 19: Cybersecurity: Industry Perspective — Part 1	11
Lecture 20: Cybersecurity: Industry Perspective — Part 2	12

Cyber Security and Privacy — Volume 02

Lectures 11–20: Contingency, Policy, Risk Management, Industry Perspective

Course: NPTEL 106106248 · **Instructor:** Prof. Saji K. Mathew, IIT Madras

Lecture 11: Contingency Planning — Part 2

Source: <https://www.youtube.com/watch?v=bpxDDAT7yE0>

Learning objectives

- Detail incident response phases: detection, containment, eradication, recovery.
- Define roles in incident response teams (IRT/CERT).
- Explain evidence preservation and forensic readiness.
- Connect incident severity classification to escalation procedures.

Core concepts

Incident response is a time-critical discipline. After preparation, the organization must **detect** anomalies (SIEM alerts, user reports, threat intelligence), **analyze** scope and root cause, **contain** spread (network isolation, account disablement), **eradicate** malware or attacker access, and **recover** services from clean backups.

The **Incident Response Team (IRT)** or **Computer Emergency Response Team (CERT)** typically includes:

- **Incident commander** — decision authority, coordinates response
- **Technical analysts** — forensics, log analysis, malware reverse engineering
- **Legal counsel** — regulatory notification, privilege, litigation hold
- **Communications/PR** — customer, media, regulator messaging
- **Business owners** — prioritize systems for restoration

Severity tiers (e.g., P1–P4) trigger different escalation paths. A P1 ransomware event affecting production ERP demands C-suite notification within minutes; a single phishing email may be handled at L1 support with playbook steps.

Forensic readiness requires immutable logs, synchronized clocks (NTP), chain-of-custody procedures, and pre-approved tools. Destroying evidence during panic recovery can hinder **post-incident review** and legal defense.

Containment trade-offs: **short-term containment** (isolate subnet) vs. **long-term eradication** (rebuild from gold images). Organizations pre-define **communication templates** for regulators (CERT-In 6-hour reporting in India for specified incidents), customers, and employees.

Key terms table

Term	Definition
IRT / CERT	Team responsible for coordinating incident response
Containment	Limiting scope and impact of an active incident
Eradication	Removing threat actor access and malware
Chain of custody	Documented handling of digital evidence
SIEM	Security Information and Event Management—log aggregation and correlation
Severity classification	Tiering incidents by business impact for escalation

Exam-oriented summary

- IR flow: detect → analyze → contain → eradicate → recover → post-incident review.
- IRT roles: commander, technical, legal, comms, business owner.
- Preserve evidence; premature rebuild can destroy forensic value.
- Severity tiers drive escalation speed and executive involvement.
- Regulatory breach notification timelines must be in playbooks.

Lecture 12: Contingency Planning — Part 3

Source: <https://www.youtube.com/watch?v=IEHL64fnd6A>

Learning objectives

- Differentiate disaster recovery (DR) from business continuity (BCP).
- Explain RTO, RPO, MTPD, and WRT in continuity planning.
- Describe backup strategies, alternate sites (hot/warm/cold), and failover testing.
- Emphasize testing and maintenance of contingency plans.

Core concepts

Disaster Recovery (DR) focuses on **restoring IT systems and data**. **Business Continuity (BCP)** ensures **critical business processes** continue—DR is often a subset of BCP. A company may restore servers (DR) but fail BCP if payroll cannot run or factories lack production schedules.

Key metrics:

Metric	Meaning
RTO	Recovery Time Objective — max downtime tolerated
RPO	Recovery Point Objective — max data loss (time between backups)
MTPD	Maximum Tolerable Period of Disruption — before unacceptable harm
WRT	Work Recovery Time — resume normal operations after systems restored

Backup strategies: full, incremental, differential; **3-2-1 rule** (3 copies, 2 media types, 1 offsite). **Immutable backups** protect against ransomware encrypting backup stores.

Alternate sites:

- **Hot site** — fully mirrored, near-instant failover; highest cost
- **Warm site** — partial hardware; hours to activate
- **Cold site** — facility only; days to operationalize

Cloud DR (multi-region replication) shifts capital expense but introduces **shared responsibility** and **dependency risk** on cloud provider.

Plans fail without **testing**. Tabletop exercises walk through scenarios; **full failover tests** validate RTO/RPO claims. Plans must be **updated** after org changes, new systems, or post-incident lessons. Annual review is minimum; quarterly for critical sectors.

Key terms table

Term	Definition
BCP	Business Continuity Plan—maintaining essential business functions
DR plan	Procedures to restore IT infrastructure and data
Failover	Switching to redundant or alternate system
Immutable backup	Backup that cannot be altered or deleted for a retention period
Tabletop exercise	Discussion-based simulation of disaster scenario
Alternate site	Secondary location or cloud region for recovery operations

Exam-oriented summary

- BCP DR; BCP covers processes, DR covers IT restoration.
- Know RTO, RPO, MTPD definitions and how they drive design.
- Hot/warm/cold sites—trade cost vs. recovery speed.
- Test plans regularly; untested DR is wishful thinking.
- 3-2-1 backup rule; immutable backups vs. ransomware.

Lecture 13: Cybersecurity Policy — Part 1

Source: <https://www.youtube.com/watch?v=8nEpUXaiZns>

Learning objectives

- Explain the purpose of cybersecurity policy in organizational governance.
- Introduce the Enterprise Information Security Policy (EISP/ESSP) structure.
- Describe how policy sets priorities and authority for security decisions.
- Relate policy to compliance, audit, and employee accountability.

Core concepts

Cybersecurity policy is the **authoritative statement** of management intent. It answers: What must we protect? Who is responsible? What behavior is required? Policies translate board risk appetite into **enforceable rules** and support **due diligence** in litigation and regulatory inquiries.

The **Enterprise Information Security Policy (EISP)**—also called Enterprise Security Policy (ESSP)—is the **top-level** document. Typical EISP sections:

1. **Purpose and scope** — applies to all employees, contractors, systems
2. **Roles and responsibilities** — board, executives, CISO, users
3. **Asset classification** — public, internal, confidential, restricted
4. **Acceptable use** — permitted and prohibited activities
5. **Compliance and enforcement** — violations, disciplinary action
6. **Policy review cycle** — annual or triggered by major changes

Policy provides the **reference top** for contingency and risk decisions—during ransomware, policy defines whether to pay ransom (often prohibited), who approves external communication, and data breach notification obligations.

Policies must be **communicated** (onboarding, annual attestation) and **enforced** consistently. A policy nobody reads is legally weak; **awareness training** links policy to daily behavior (password rules, reporting suspicious email).

Policy sits above **standards** (mandatory technical specs) and **procedures** (operational steps). Exam questions often ask to **draft policy objectives** vs. **technical controls**—policies state *what* and *why*; standards state *how*.

Key terms table

Term	Definition
EISP / ESSP	Enterprise Information/Security Policy—top-level security policy
Policy	Management mandate governing organizational behavior
Acceptable use policy (AUP)	Rules for using organizational IT resources
Asset classification	Categorizing data/systems by sensitivity
Attestation	Employee acknowledgment of reading and accepting policy
Enforcement	Sanctions for policy violations

Exam-oriented summary

- Policy = management intent; foundation for compliance and accountability.
 - EISP sections: purpose, roles, classification, acceptable use, enforcement, review.
 - Policy guides incident decisions (ransom, notification, communication).
 - Distinguish policy (what/why) from standards and procedures (how).
 - Communication + enforcement essential for legal and cultural effectiveness.
-

Lecture 14: Cybersecurity Policy — Part 2

Source: <https://www.youtube.com/watch?v=snROvNy3wf8>

Learning objectives

- Define Issue-Specific Security Policies (ISSP) and their domains.
- Explain System-Specific Security Policies (SySSP) for applications and platforms.
- Map ISSP topics: acceptable use, email, internet, remote access, BYOD.
- Show how policy hierarchy cascades from enterprise to system level.

Core concepts

Issue-Specific Security Policies (ISSP) address particular **topics** or **risk domains** without repeating the entire EISP. Common ISSPs:

ISSP	Typical provisions
Acceptable Use	Personal use limits, prohibited sites, software installation
Email & Communications	Phishing reporting, encryption for sensitive content, retention
Internet Use	Web filtering, social media, download restrictions
Remote Access & VPN	MFA requirement, split tunneling, endpoint security
BYOD / Mobile	Containerization, MDM enrollment, lost device wipe
Password / Authentication	Length, rotation (where still used), MFA, lockout
Data Classification & Handling	Labeling, storage, transmission, disposal rules

System-Specific Security Policies (SySSP) apply to **individual systems**—ERP, CRM, HR database, SCADA. They document:

- **Authorized users and roles**
- **Data types processed**
- **Security controls** (encryption, logging, patching SLA)
- **Interconnections** and data flows
- **Owner and administrator** contacts

Example: HR payroll system SySSP specifies that salary data is **restricted**, accessible only to HR roles, encrypted at rest, with quarterly access reviews.

The **policy hierarchy**:

EISP (enterprise)
 ISSP (topic-specific)
 SySSP (system-specific)
 Standards & Procedures

Conflicts resolve **upward**—SySSP cannot weaken EISP. **Exceptions** require documented risk acceptance and approval authority.

Key terms table

Term	Definition
ISSP	Issue-Specific Security Policy—topic-focused rules
SySSP	System-Specific Security Policy—per-application/platform policy
BYOD	Bring Your Own Device—personal devices accessing corporate resources
MDM	Mobile Device Management—enforcing policy on mobile endpoints
Policy exception	Documented deviation from policy with approved risk acceptance
Data handling	Rules for storing, transmitting, destroying classified data

Exam-oriented summary

- ISSP covers domains: AUP, email, internet, remote access, BYOD, passwords.
- SySSP is per-system: users, data, controls, owners, interconnections.
- Hierarchy: EISP → ISSP/SySSP → standards → procedures.
- Exceptions need formal approval—cannot silently weaken enterprise policy.
- Map exam scenarios to correct policy level (enterprise vs. issue vs. system).

Lecture 15: Cybersecurity Policy — Part 3

Source: <https://www.youtube.com/watch?v=MZIDHGdqm3w>

Learning objectives

- Describe policy development lifecycle: draft, review, approve, publish, maintain.
- Address policy–culture alignment and security behavior change.
- Explain security awareness programs and their measurement.
- Integrate policy with HR, legal, and audit functions.

Core concepts

Policy development follows a structured lifecycle:

1. **Initiate** — trigger (new regulation, audit finding, incident)

2. **Draft** — cross-functional team (legal, IT, HR, business)
3. **Review** — stakeholder comment, impact analysis
4. **Approve** — executive or board sign-off for EISP
5. **Publish** — accessible repository, version control
6. **Train** — role-based awareness
7. **Enforce** — monitoring, violations, remediation
8. **Maintain** — periodic review, post-incident updates

Security culture determines whether policy changes behavior. Factors: leadership modeling, **blame-free reporting** of mistakes, incentives for reporting phishing, and avoiding **security fatigue** (too many rules ignored).

Awareness programs use multiple channels: e-learning, phishing simulations, posters, town halls. Measure **click rates** on simulated phishing, **report rates**, quiz scores, and **incident trends**. Awareness is a **leading control**; it complements technical controls but does not replace them.

HR integration: policies belong in employment contracts; termination must trigger **access revocation** (joiner-mover-leaver process). **Legal** ensures policy language aligns with labor law and privacy obligations. **Audit** tests policy compliance through sampling and control testing.

Policy connects forward to **risk management**: unmitigated risks may require **new policy** or **policy exceptions** documented in the risk register.

Key terms table

Term	Definition
Policy lifecycle	End-to-end process from draft through retirement
Security culture	Shared values and behaviors around security
Phishing simulation	Controlled fake phishing to measure user susceptibility
Joiner-mover-leaver (JML)	HR-driven access provisioning and deprovisioning
Version control	Tracking policy revisions with effective dates
Blame-free reporting	Encouraging incident disclosure without punitive default

Exam-oriented summary

- Policy lifecycle: initiate → draft → review → approve → publish → train → enforce → maintain.
- Culture and leadership determine policy effectiveness.
- Measure awareness via simulations, reports, training completion.
- HR (JML), legal, audit are key stakeholders in policy programs.
- Policy gaps surface in risk register; exceptions need formal approval.

Lecture 16: Risk Management — Part 1

Source: <https://www.youtube.com/watch?v=v7KtPLhSMkU>

Learning objectives

- Define information security risk and its components: threat, vulnerability, asset, impact.
- Explain risk identification methods: asset inventory, threat modeling, vulnerability assessment.
- Introduce qualitative vs. quantitative risk analysis.
- Relate risk management to GRC and organizational objectives.

Core concepts

Risk is the potential for loss or harm when a **threat** exploits a **vulnerability** affecting an **asset**.
Formal expression:

Risk = Likelihood $\times$ Impact (with context-specific modifiers)

Risk identification begins with **asset inventory**—hardware, software, data, people, reputation. **Threat modeling** (STRIDE, attack trees) asks what adversaries want and how they might succeed. **Vulnerability assessment** (scanning, pen testing, audits) finds weaknesses.

Analysis type	Approach	Use case
Qualitative	Low/Medium/High scales; risk matrices	Fast prioritization, limited data
Quantitative	ALE, SLE, ARO, monetary values	Budget justification, insurance

Quantitative terms:

- **SLE** (Single Loss Expectancy) = Asset value $\times$ Exposure factor
- **ARO** (Annualized Rate of Occurrence) = expected frequency per year
- **ALE** (Annualized Loss Expectancy) = SLE $\times$ ARO

Risk management aligns with **ISO 31000** and **NIST SP 800-30**: establish context, identify, analyze, evaluate, treat, monitor. It is the **proactive** complement to **contingency planning** (reactive).

Risk must be framed in **business terms**—revenue at risk, regulatory fines, customer churn—not only CVE counts.

Key terms table

Term	Definition
Threat	Potential cause of unwanted incident
Vulnerability	Weakness that can be exploited
Likelihood	Probability threat exploits vulnerability
Impact	Magnitude of harm if risk materializes
Risk matrix	Grid mapping likelihood vs. impact for prioritization
ALE	Annualized Loss Expectancy—expected yearly loss from a risk

Exam-oriented summary

- Risk = threat + vulnerability + asset + impact; express likelihood $\times$ impact.
 - Identification: asset inventory, threat modeling, vulnerability assessment.
 - Qualitative (matrices) vs. quantitative ($ALE = SLE \times ARO$).
 - Risk management is proactive; contingency is reactive—both required.
 - Frame risk in business language for executive decisions.
-

Lecture 17: Risk Management — Part 2

Source: <https://www.youtube.com/watch?v=WtbyE4GE7Zc>

Learning objectives

- Describe risk treatment options: mitigate, transfer, avoid, accept.
- Explain control selection and cost-benefit analysis.
- Introduce residual risk and risk acceptance documentation.
- Connect risk treatment to security controls catalog (ISO 27002, NIST 800-53).

Core concepts

Risk treatment strategies (often called the **4 Ts**):

Strategy	Description	Example
Mitigate	Reduce likelihood or impact via controls	Deploy MFA, patch systems
Transfer	Shift financial consequence	Cyber insurance, outsourcing with SLA
Avoid	Eliminate activity creating risk	Discontinue legacy protocol
Accept	Acknowledge residual risk within appetite	Documented sign-off by owner

Control selection maps risks to safeguards from **ISO 27002** or **NIST SP 800-53** families (access control, audit, incident response, etc.). **Cost-benefit analysis** compares control cost to **risk reduction**—not every high risk warrants expensive controls if cheaper combinations achieve acceptable residual risk.

Residual risk remains after controls. **Risk acceptance** requires **named approver** (asset owner or executive) when residual risk exceeds standard thresholds but business chooses to proceed—common for legacy systems pending replacement.

Defense in depth stacks controls so failure of one layer does not cause total compromise. **Compensating controls** substitute when primary control is infeasible (e.g., enhanced monitoring when encryption on legacy app is impossible short-term).

Risk treatment feeds **project roadmaps**: prioritized remediation with budgets and deadlines tracked in GRC tools.

Key terms table

Term	Definition
Risk mitigation	Implementing controls to reduce risk
Risk transfer	Insurance or contractual liability shift
Risk avoidance	Eliminating the risk-creating activity
Risk acceptance	Formal approval to live with residual risk
Residual risk	Risk remaining after controls applied
Compensating control	Alternative safeguard when primary control unavailable

Exam-oriented summary

- Four treatments: mitigate, transfer, avoid, accept—give examples of each.
- Residual risk must be within appetite or formally accepted.
- Map controls to ISO 27002 / NIST families in answers.
- Cost-benefit: control spend vs. risk reduction, not risk elimination at any cost.
- Compensating controls document exceptions with equivalent protection.

Lecture 18: Risk Management — Part 3

Source: <https://www.youtube.com/watch?v=2TsAnaO75ck>

Learning objectives

- Implement ongoing risk monitoring and review cycles.
- Integrate third-party and supply-chain risk into enterprise assessments.
- Describe key risk indicators (KRIs) and risk reporting to governance bodies.
- Close risk management module and transition to industry/technical perspectives.

Core concepts

Risk management is **continuous**. **Monitoring** tracks KRIs: unpatched critical CVEs, failed login spikes, vendor audit overdue, open high findings from pen tests. **Triggers** initiate re-assessment when architecture changes, new regulations emerge, or major incidents occur in the industry.

Third-party risk is critical—Target breach via HVAC vendor illustrates **supply-chain attack surface**. Vendor risk management includes:

- Security questionnaires and **SOC 2 / ISO 27001** evidence
- Contractual **SLAs** and **right to audit**
- **Fourth-party** awareness (vendor's subcontractors)
- **Continuous monitoring** of vendor breach news

Risk reporting to board and executives uses **heat maps**, top-10 risk lists, and **trend analysis**. Reports should avoid jargon; tie to **strategic objectives** and **regulatory deadlines**.

Integration with **contingency**: high residual risks may require **enhanced IR playbooks** or **crisis exercises**. Integration with **policy**: unacceptable practices become policy violations.

The course next examines **industry perspective**—how attacks manifest in practice (defense technologies, exploits, threat landscape)—bridging management frameworks to **operational security reality**.

Key terms table

Term	Definition
KRI	Key Risk Indicator—metric signaling increasing risk
Third-party risk	Exposure from vendors, partners, suppliers
SOC 2	Audit report on service organization controls
Right to audit	Contractual authority to assess vendor security
Supply-chain risk	Threats introduced via suppliers and software dependencies
Risk heat map	Visual plot of risks by likelihood and impact

Exam-oriented summary

- Risk management is continuous—monitor KRIs, reassess on triggers.
- Third-party risk: questionnaires, certifications, contracts, monitoring.
- Board reporting: heat maps, trends, business-aligned language.
- Link residual risk to contingency planning and policy updates.
- Sets foundation for industry attack/exploit modules (L19–L21).

Lecture 19: Cybersecurity: Industry Perspective — Part 1

Source: <https://www.youtube.com/watch?v=F5KwJEVGIxg>

Learning objectives

- Survey the contemporary threat landscape from an industry practitioner view.
- Classify attack types: malware, social engineering, web attacks, network attacks.
- Explain defense technologies at a high level: perimeter, endpoint, network segmentation.
- Relate industry threats to earlier risk and policy frameworks.

Core concepts

The **industry perspective** translates managerial frameworks into **real attack patterns** security teams face daily. Threat landscape reports (Verizon DBIR, Mandiant, CrowdStrike) show dominant vectors: **credential theft**, **phishing**, **vulnerability exploitation**, **ransomware**, and **supply-chain compromise**.

Attack categories:

Category	Examples
Malware	Ransomware, trojans, rootkits, wipers
Social engineering	Phishing, vishing, pretexting, baiting
Web application	SQL injection, XSS, CSRF, insecure APIs

Category	Examples
Network	DDoS, MITM, DNS hijacking, port scanning
Insider	Data theft, sabotage, negligence

Defense technologies (overview—detailed in Lectures 22–24):

- **Perimeter** — firewalls, WAF, IDS/IPS
- **Endpoint** — EDR, antivirus, application whitelisting
- **Identity** — IAM, MFA, PAM (privileged access management)
- **Network** — segmentation, VLANs, zero-trust architecture
- **Data** — DLP, encryption, tokenization

Defense in depth assumes **breach inevitability**—aligns with Zero Trust (“never trust, always verify”). Industry shift: from **castle-and-moat** perimeter to **identity-centric** security for cloud and remote work.

Managers must understand **ATT&CK framework** (MITRE) as common vocabulary mapping **tactics** (initial access, persistence, exfiltration) to **detections** and **controls**.

Key terms table

Term	Definition
EDR	Endpoint Detection and Response—advanced endpoint monitoring
WAF	Web Application Firewall—filters HTTP traffic to web apps
IDS/IPS	Intrusion Detection/Prevention System
DLP	Data Loss Prevention—monitors sensitive data movement
Zero Trust	Security model verifying every access request continuously
MITRE ATT&CK	Knowledge base of adversary tactics and techniques

Exam-oriented summary

- Dominant vectors: credentials, phishing, exploits, ransomware, supply chain.
- Classify attacks: malware, social, web, network, insider.
- Defense layers: perimeter, endpoint, identity, network, data.
- Zero Trust replaces pure perimeter model for cloud/mobile era.
- MITRE ATT&CK links industry threats to detections and controls.

Lecture 20: Cybersecurity: Industry Perspective — Part 2

Source: <https://www.youtube.com/watch?v=ROHhs7PMIGw>

Learning objectives

- Analyze exploit lifecycle: reconnaissance, weaponization, delivery, exploitation, installation, C2, actions on objectives.

- Describe common exploit targets: unpatched software, misconfigurations, weak credentials.
- Explain threat intelligence and its use in proactive defense.
- Discuss industry sectors with distinct risk profiles (finance, healthcare, manufacturing, OT).

Core concepts

The **cyber kill chain** (Lockheed Martin) and **MITRE ATT&CK** describe attack progression:

1. **Reconnaissance** — OSINT, scanning, social media mining
2. **Weaponization** — pairing exploit with payload
3. **Delivery** — email attachment, malicious link, USB drop
4. **Exploitation** — triggering vulnerability
5. **Installation** — persistence (backdoor, scheduled task)
6. **Command & Control (C2)** — attacker communication channel
7. **Actions on objectives** — data theft, ransomware deployment, sabotage

Exploits target **unpatched CVEs**, **default credentials**, **misconfigured cloud buckets** (S3 public), and **overprivileged service accounts**. **Patch management** and **vulnerability prioritization** (CVSS, EPSS, asset criticality) are operational necessities.

Threat intelligence (strategic, operational, tactical) informs blocklists, detection rules, and hunt hypotheses. Sources: ISACs, commercial feeds, open sources (CISA advisories). Intelligence without **integration into SIEM/SOAR** has limited value.

Sector differences:

- **Finance** — fraud, SWIFT attacks, regulatory scrutiny
- **Healthcare** — PHI value, legacy devices, availability criticality
- **Manufacturing/OT** — safety, downtime cost, air-gapped vs. connected tension
- **Technology/SaaS** — customer data concentration, supply-chain attacks (SolarWinds pattern)

Industry perspective reinforces that **managerial risk choices** (patch SLAs, vendor access, segmentation) directly affect exploit success rates.

Key terms table

Term	Definition
Kill chain	Sequential stages of cyber attack
CVE	Common Vulnerabilities and Exposures—standardized ID
CVSS	Common Vulnerability Scoring System—severity score
C2	Command and control—infrastructure for remote attacker control
Threat intelligence	Evidence-based knowledge of threats for decision-making
OT security	Protecting operational technology in industrial environments

Exam-oriented summary

- Know kill chain / ATT&CK stages from recon to actions on objectives.
- Top exploit enablers: missing patches, misconfig, weak credentials.

- Threat intelligence must feed detection and response tools.
- Sector context changes priority: PHI, OT safety, financial fraud, SaaS supply chain.
- Industry module connects technical reality to GRC, policy, and risk choices.

End of Volume 02 (Lectures 11–20). Continue with Volume 03 (Lectures 21–30) when available.